

PRUEBAS Y VALIDACIONES DEL LABORATORIO FORTIGATE

Evidencias de conectividad, segmentación y controles de seguridad

1. Objetivo de las pruebas

Esta sección documenta las pruebas realizadas para comprobar el funcionamiento de las políticas de seguridad, la segmentación entre VLANs, el acceso a los servicios autorizados y la respuesta del FortiGate ante eventos de seguridad controlados.

2. Resumen de validaciones

Prueba	Resultado observado	Estado
HTTPS USERS → WEB	HTTP/1.1 200 OK	Validado
USERS → DB/3306	Timeout	Validado
WEB → DB/3306	Conexión exitosa	Validado
WEB → DB/22	Timeout	Validado
SQL Injection	Payload de prueba ejecutado y origen en cuarentena	Validado
File Filter EXE	Intento de descarga ejecutado; requiere log de File Filter para probar bloqueo	Evidencia parcial
DoS controlado	1000 paquetes enviados, 97% packet loss	Prueba ejecutada

3. HTTPS — USERS → WEB

Desde el equipo user-client se ejecutó:

```
curl -k -i -m 5 https://10.21.39.130/
```

Resultado observado: el servidor respondió HTTP/1.1 200 OK y mostró la página del WEB Server.

```
adrian@user-client:~$ curl -k -i -m 5 https://10.21.39.130/
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Sat, 26 Sep 2026 00:33:01 GMT
Content-Type: text/html
Content-Length: 81
Last-Modified: Fri, 25 Sep 2026 06:24:38 GMT
Connection: keep-alive
ETag: "6ab613a6-51"
Accept-Ranges: bytes

<h1> WEB SERVER - Seguridad de Redes</h1><p>HTTPS funcionando correctamente.</p>
adrian@user-client:~$
```

Figura 1. Acceso HTTPS exitoso desde user-client hacia 10.21.39.130.

4. USERS → DB bloqueado

Desde user-client se intentó establecer una conexión TCP directa al servicio MySQL:

```
nc -vz -w 5 10.21.39.146 3306
```

Resultado observado: la conexión expiró por timeout, confirmando que USERS no puede acceder directamente al DB Server por TCP/3306.

```
adrian@user-client:~$ nc -vz -w 5 10.21.39.146 3306
nc: connect to 10.21.39.146 port 3306 (tcp) timed out: Operation now in progress
adrian@user-client:~$
```

Figura 2. Timeout desde USERS hacia DB Server por TCP/3306.

5. WEB → DB permitido por MySQL

Desde web-server se realizó la conexión al puerto MySQL del DB Server:

```
nc -vz -w 5 10.21.39.146 3306
```

Resultado observado: la conexión fue exitosa en TCP/3306.

```
adrian@web-server:~$ nc -vz -w 5 10.21.39.146 3306
Connection to 10.21.39.146 3306 port [tcp/mysql] succeeded!
adrian@web-server:~$
```

Figura 3. Conexión exitosa de WEB Server hacia DB Server por TCP/3306.

6. WEB → DB por otro puerto

Desde web-server se intentó acceder al puerto SSH del DB Server:

```
nc -vz -w 5 10.21.39.146 22
```

Resultado observado: la conexión expiró por timeout. Esto respalda que el WEB Server tiene acceso al DB únicamente por el servicio autorizado.

```
adrian@web-server:~$ nc -vz -w 5 10.21.39.146 22
nc: connect to 10.21.39.146 port 22 (tcp) timed out: Operation now in progress
adrian@web-server:~$
```

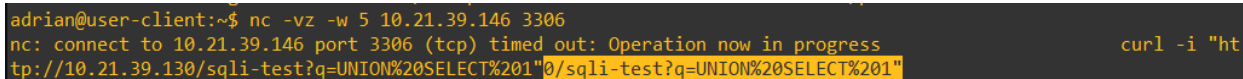
Figura 4. Puerto TCP/22 bloqueado entre WEB Server y DB Server.

7. SQL Injection controlado

Se utilizó un endpoint HTTP de laboratorio para enviar un patrón controlado de SQL Injection que pudiera ser inspeccionado por la firma personalizada del IPS.

```
curl -i "http://10.21.39.130/sqli-test?q=UNION%20SELECT%201"
```

Resultado esperado/validado: detección por la firma IPS LAB.SQLI.TEST y aplicación de la acción de cuarentena al origen.



```
adrian@user-client:~$ nc -vz -w 5 10.21.39.146 3306
nc: connect to 10.21.39.146 port 3306 (tcp) timed out: Operation now in progress
http://10.21.39.130/sqli-test?q=UNION%20SELECT%201
```

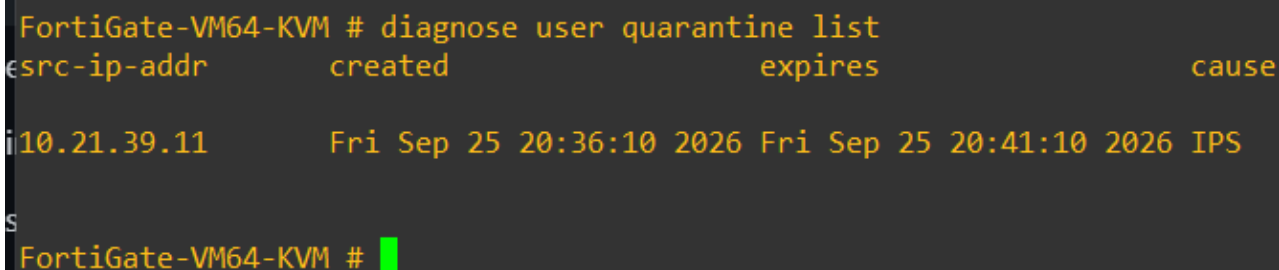
Figura 5. Ejecución del payload SQLi controlado desde user-client.

8. Verificación de cuarentena

En la consola del FortiGate se verificó la lista de equipos en cuarentena:

```
diagnose user quarantine list
```

Resultado observado: la dirección 10.21.39.11 aparece en cuarentena con causa IPS.



```
FortiGate-VM64-KVM # diagnose user quarantine list
src-ip-addr      created          expires          cause
10.21.39.11      Fri Sep 25 20:36:10 2026 Fri Sep 25 20:41:10 2026 IPS
FortiGate-VM64-KVM #
```

Figura 6. Dirección 10.21.39.11 en cuarentena por acción del IPS.

9. File Filter EXE

Desde user-client se realizó un intento de descarga del ejecutable de prueba:

```
curl -v -o prueba.exe http://10.21.39.130/prueba.exe
```

```
adrian@user-client:~$
adrian@user-client:~$ curl -v -o prueba.exe http://10.21.39.130/prueba.exe
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
0         0     0    0     0     0      0      0  0*   Trying 10.21.39.130:80...
* Connected to 10.21.39.130 (10.21.39.130) port 80
> GET /prueba.exe HTTP/1.1
> Host: 10.21.39.130
> User-Agent: curl/8.5.0
> Accept: */*
>
< HTTP/1.1 200 OK
< Content-Length: 4417
< Connection: Close
< Cache-Control: no-cache
< Content-Type: text/html; charset=utf-8
< X-Frame-Options: SAMEORIGIN
<
{ [1294 bytes data]
100 4417 100 4417    0     0  92216      0  0*   93978
* Closing connection
adrian@user-client:~$
```

Figura 7. Ejecución de la solicitud HTTP del archivo prueba.exe.

Observación importante: esta captura muestra HTTP/1.1 200 OK y una transferencia de 4417 bytes. Por lo tanto, esta imagen no debe usarse por sí sola para afirmar que el archivo fue bloqueado. La evidencia definitiva del control File Filter debe ser la captura del registro de FortiGate donde aparezca File Name: prueba.exe y Action: blocked.

10. Prueba DoS controlada

Desde user-client se generó tráfico SYN controlado contra HTTPS/443 del WEB Server:

```
sudo hping3 -S -p 443 -i u1000 -c 1000 10.21.39.130
```

Resultado observado: se transmitieron 1000 paquetes y se registró aproximadamente 97% de pérdida durante la prueba.

```

Host: 10.21.39.130
User-Agent: curl/8.5.0
Accept: */*

HTTP/1.1 200 OK
Content-Length: 4417
Connection: Close
Cache-Control: no-cache
Content-Type: text/html; charset=utf-8
X-Frame-Options: SAMEORIGIN

[1294 bytes data]
00 4417 100 4417 0 0 92216 0 --:--:-- --:--:-- --:--:-- 93978
Closing connection
adrian@user-client:~$ sudo hping3 -S -p 443 -i u1000 -c 1000 10.21.39.130
sudo] password for adrian:
sorry, try again.
sudo] password for adrian:
PING 10.21.39.130 (ens3 10.21.39.130): S set, 40 headers + 0 data bytes
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=0 win=64240 rtt=9.9 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=1 win=64240 rtt=10.4 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=2 win=64240 rtt=13.8 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=3 win=64240 rtt=12.9 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=4 win=64240 rtt=11.7 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=5 win=64240 rtt=10.3 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=6 win=64240 rtt=9.1 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=7 win=64240 rtt=16.8 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=8 win=64240 rtt=20.9 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=9 win=64240 rtt=17.9 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=10 win=64240 rtt=15.9 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=11 win=64240 rtt=6.2 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=12 win=64240 rtt=11.1 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=13 win=64240 rtt=12.8 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=14 win=64240 rtt=11.2 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=15 win=64240 rtt=12.4 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=16 win=64240 rtt=10.8 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=17 win=64240 rtt=14.3 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=18 win=64240 rtt=16.1 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=19 win=64240 rtt=16.0 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=20 win=64240 rtt=13.5 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=21 win=64240 rtt=16.3 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=22 win=64240 rtt=18.3 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=23 win=64240 rtt=21.0 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=24 win=64240 rtt=20.2 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=25 win=64240 rtt=18.3 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=26 win=64240 rtt=16.0 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=27 win=64240 rtt=12.4 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=28 win=64240 rtt=9.1 ms
en=44 ip=10.21.39.130 ttl=63 DF id=0 sport=443 flags=SA seq=29 win=64240 rtt=10.0 ms

-- 10.21.39.130 hping statistic ---
000 packets transmitted, 30 packets received, 97% packet loss
round-trip min/avg/max = 6.2/13.8/21.0 ms
adrian@user-client:~$

```

Figura 8. Generación controlada de tráfico SYN contra el WEB Server.

Para demostrar formalmente que la política DoS del FortiGate detectó o actuó sobre este tráfico, debe acompañarse esta captura con el evento correspondiente en Log & Report → Anomaly.

11. Conclusión de las validaciones

Las pruebas confirman la segmentación principal del laboratorio: los usuarios pueden acceder al WEB Server por HTTPS, no pueden conectarse directamente al DB Server por MySQL, y el WEB Server sí puede acceder a MySQL mientras otros puertos permanecen bloqueados. Además, se documentó la ejecución de una prueba SQLi controlada y la cuarentena del origen por el IPS. Para File Filter y DoS, los registros específicos de FortiGate deben conservarse como evidencia complementaria de la acción aplicada por cada perfil de seguridad.